L'objectif est d'apprendre à sécuriser un système Windows en simulant une attaque de reconnaissance. On ne se contente plus de lister les ports (comme au TP 1), on cherche à comprendre comment un attaquant pourrait exploiter ces services pour s'introduire dans le réseau.

## Vérification de l'adresses ip

Ipconfig

```
Carte Ethernet Ethernet1 :

   Suffixe DNS propre à la connexion. . . :
   Adresse IPv6 de liaison locale. . . . .: fe80::79c7:8a8a:4612:225e%10
   Adresse IPv4. . . . . . . . . . . . . .: 192.168.56.20
   Masque de sous-réseau. . . . . . . . . : 255.255.255.0
   Passerelle par défaut. . . . . . . . . : 192.168.56.1

C:\Users\laurene>
```

**verifiez que la machineest accesible depuis kali avec la commende ping 192.168.56.20**

```
┌──(root㉿kali)-[/home/laurene]
└─# ping 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=1.88 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=1.49 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=1.47 ms
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=1.38 ms
^Z
zsh: suspended  ping 192.168.56.20
```

**desactivation des pare feu avec la commande netsh advfirewall set allprofilles state off**

```
C:\Windows\system32> netsh advfirewall set allprofiles state off
Ok.
```

**Pour voir si les pare feu on bien été desactivé**

```
C:\Windows\system32> netsh advfirewall show allprofilles state
La commande suivante n'a pas été trouvée : advfirewall show allprofilles state.

C:\Windows\system32> netsh advfirewall show allprofiles state

Paramètres Profil de domaine :
----------------------------------------------------------------------
État                                      Inactif

Paramètres Profil privé :
----------------------------------------------------------------------
État                                      Inactif

Paramètres Profil public :
----------------------------------------------------------------------
État                                      Inactif
Ok.
```

Partie 1 : Action : nmap -sS 192.168.56.20

```
┌──(root㉿kali)-[/home/laurene]
└─# nmap -sS 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 17:14 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00083s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:F4:AA:78 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.13 seconds
```

En désactivant le pare-feu (firewall), tu exposes la "nudité" du système. Tu devrais voir les ports 135, 139, 445 et parfois 3389. Ces ports sont les portes d'entrée classiques de Windows. Un port ouvert sans pare-feu est une cible immédiate.

Partie 2 : Identification des services avec la commande nmap -sV 192.168.56.20

```
┌──(root㉿kali)-[/home/laurene]
└─# nmap -sV 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 17:15 +0200
Nmap scan report for 192.168.56.20
Host is up (0.0015s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE       VERSION
135/tcp open  msrpc         Microsoft Windows RPC
139/tcp open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds?
MAC Address: 00:0C:29:F4:AA:78 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.56 seconds
```

Le -sV (Version Detection) interroge le service pour qu'il dise exactement qui il est (ex: Microsoft Windows RPC). Si un attaquant connaît la version exacte, il peut chercher l'exploit spécifique sur Searchsploit en 2 secondes.

Partie 3 : Utilisation des scripts Nmap pour SMB

Commande nmap –p 445 –script smd-os-dicovery 192.168.56.20 permet de recuperer:

- La version windows
- Le non de la machine

- Le groupe de travail

```
┌──(root㉿kali)-[/home/laurene]
└─# nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 17:25 +0200
Nmap scan report for 192.168.56.20
Host is up (0.0018s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:F4:AA:78 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 4.92 seconds
```

Ce que tu découvres : Le nom de l'ordinateur (DESKTOP-F1VI05N) et parfois le nom de l'utilisateur ou du domaine.

Pourquoi c'est grave ? Cela permet de faire de l'énumération. L'attaquant connaît maintenant le nom de sa cible, ce qui est crucial pour des attaques ciblées ou des scans de réseau plus larges.

**Détection de vulnérabilités SMB**

nmap --script smb-vuln* -p 445 192.168.56.20

```
laurene@kali: ~
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:F4:AA:78 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.03 seconds

┌──(laurene㉿kali)-[~]
└─$ nmap -p 3389 --script rdp-enum-encryption 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 19:04 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00099s latency).

PORT     STATE SERVICE
3389/tcp open  ms-wbt-server
| rdp-enum-encryption:
|   Security layer
|     CredSSP (NLA): SUCCESS
|     CredSSP with Early User Auth: SUCCESS
|_    RDSTLS: SUCCESS
MAC Address: 00:0C:29:F4:AA:78 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 6.70 seconds

┌──(laurene㉿kali)-[~]
└─$
```

Le script teste si la machine est sensible à des failles historiques comme EternalBlue ou si elle a une mauvaise configuration comme le "Message Signing Not Required". Comme nous l'avons vu,

si la signature n'est pas obligatoire, l'attaquant peut intercepter les fichiers qui circulent sur le réseau.

**Analyse du service RDP (Bureau à distance)**

Action : nmap -p 3389 --script rdp-enum-encryption 192.168.56.20

```
┌──(laurene㉿kali)-[~]
└─$ nmap -p 3389 --script rdp-enum-encryption 192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-16 18:52 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00097s latency).

PORT     STATE SERVICE
3389/tcp open  ms-wbt-server
| rdp-enum-encryption:
|   Security layer
|     CredSSP (NLA): SUCCESS
|     CredSSP with Early User Auth: SUCCESS
|_    RDSTLS: SUCCESS
MAC Address: 00:0C:29:F4:AA:78 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 7.49 seconds
```

Le port 3389 est le plus attaqué au monde par force brute . Le script vérifie si le chiffrement est assez solide pour empêcher un espion de voir ton écran à distance.

**Analyse globale (Réponses aux questions)**

- **Quels sont les risques ?** Prise de contrôle à distance (RCE), vol de données par interception SMB, et intrusion par Bureau à Distance.
- **Service le plus dangereux ?** Le SMB (445) car il est lié au noyau du système.
- **Mesures de durcissement (Hardening) :** 1. Réactiver le Pare-feu.

**Analyse globale de la sécurité**

**Identification des services critiques**

D'après mes scans Nmap, deux services critiques ont été identifiés sur la cible 192.168.56.20 :

- SMB (Microsoft-DS) sur le port 445 : Ce service est ouvert et fonctionnel. Il est critique car il gère le partage de fichiers et l'administration à distance.

- RDP (Bureau à distance) sur le port 3389 : Ce service a été détecté comme fermé (closed) lors du scan, ce qui signifie qu'il n'est pas exposé actuellement.

**Détermination des risques**

L'analyse avec les scripts smb-vuln* a mis en évidence les risques suivants :

- Risque d'interception (MITM) : Le service SMB peut être vulnérable si la signature des messages n'est pas requise, permettant à un attaquant d'intercepter des documents sensibles.
- Risque de reconnaissance : Bien que les scripts n'aient pas trouvé de faille critique immédiate (MS17-010 par exemple), le simple fait que le port soit ouvert permet à un attaquant de tenter des attaques par force brute sur les mots de passe.
- Risque lié au RDP : Si le RDP venait à être activé sans un chiffrement fort, il deviendrait la cible principale pour une prise de contrôle totale de la machine.

**Mesures de sécurisation proposées**

- Pour améliorer la sécurité de cette machine, je propose les mesures suivantes :
- Désactiver SMBv1 : Ce protocole est obsolète et contient des failles majeures. Il faut forcer l'utilisation de SMBv2 ou SMBv3.
- Activer la signature SMB (Message Signing) : Obliger la signature pour empêcher les attaques de l'homme du milieu (MITM).
- Limiter l'accès RDP : Si le Bureau à distance est nécessaire, il doit être restreint à certaines adresses IP uniquement et utiliser une authentification forte.
- Réactiver le Pare-feu Windows : Une fois les tests terminés, le pare-feu doit être réactivé en configurant des règles d'exclusion précises au lieu de le couper totalement.
- Politique de mots de passe : Imposer des mots de passe complexes pour tous les comptes utilisateurs afin de bloquer les tentatives de brute force détectées par Nmap.

En entreprise, un poste Windows mal configuré est un "maillon faible". Si un seul ordinateur est compromis, l'attaquant peut s'en servir de rebond pour attaquer toute l'entreprise. Le rôle de l'administrateur est de réduire cette "surface d'attaque" en fermant tout ce qui n'est pas indispensable.